

Controlling Autonomous AI

Working paper

Matthew Apps

DOI: [10.5281/zenodo.23043277](https://doi.org/10.5281/zenodo.23043277)

Abstract

AI agents are moving from supporting decisions to taking actions themselves. They can move money, change systems, alter records, grant access, execute code and instruct other agents. That creates a different control problem from the one organisations have traditionally faced.

Current approaches increasingly address agent identity, delegated authority, permissions, monitoring and intervention. These controls matter, but their presence does not necessarily mean that the organisation still controls the outcome.

A system may be correctly identified, properly authorised, bounded, fully logged and equipped with a shutdown mechanism, yet still act too quickly or across too many connected systems for those controls to prevent an unacceptable result.

I use the term Control Illusion for the gap between having controls and those controls still being able to affect the outcome.

It proposes IABEI - Identity, Authority, Boundaries, Evidence and Intervention - as an assurance structure for consequential autonomous action. IABEI does not replace identity management, zero trust, delegated-authority models, runtime controls or provenance systems. Its purpose is to test whether those controls join together into a working control chain.

Control Margin then asks a simpler question: can intervention still take effect before the outcome becomes unavoidable?

AI will fail. The control problem is whether that failure can cause serious harm.

1. The control problem

There is already a lot of work being done on how autonomous AI should be controlled. Agents can be given their own identities, their permissions can be restricted, authority can be delegated for a particular purpose, actions can be logged, policy engines can block certain behaviour, humans can approve important decisions and systems can be stopped when something goes wrong.

The direction of current work is sensible. The World Economic Forum and Capgemini's Agent Capability and Authorization Profile, for example, treats delegated authority as something that should be explicit, enforceable and auditable throughout the lifecycle of an agent. Microsoft similarly recommends scoped permissions, deterministic escalation and system-level mechanisms for stopping autonomous behaviour.

But there is a more basic issue: do these controls still give the organisation control over the outcome?

Consider a payment agent that can complete a transaction in one second. The organisation detects unusual behaviour after five seconds and then takes another thirty seconds for somebody to understand what has happened and decide whether to intervene. The agent can still be stopped, and both the monitoring and shutdown controls may have worked exactly as designed, but neither could affect that transaction because the payment had already completed.

Nothing has necessarily failed in the conventional sense. The problem is that the control process was too slow to affect the outcome. The organisation can show that it had controls, but it cannot show that those controls gave it control over that transaction.

That distinction is the starting point for this paper.

The term consequential autonomous action is used here to mean an action taken by an AI system that can materially change an organisation's financial, operational, legal, security, customer or reputational position without requiring another human to execute that change.

2. Meaningful control

Meaningful human control is not a new idea. Existing work has considered the conditions under which humans retain genuine responsibility and control over autonomous systems, including whether behaviour remains traceable to responsible people and responsive to their reasons and intentions. More recent work on agentic AI also argues that traditional assumptions about humans monitoring and correcting systems in real time become difficult to sustain as systems operate at greater speed, scale and complexity.

In this paper, meaningful control means that the organisation can still keep autonomous action inside the limits it has set.

That does not mean that a human must approve every action, understand every internal step taken by the AI, or predict every situation the system might encounter. None of those requirements will scale.

Sometimes control can operate at runtime: the problem is detected and intervention still has time to work. Where that is not realistic, control has to be built in earlier by constraining what the system can reach in the first place.

This distinction matters. If a payment settles in less than a second, it may be unrealistic to expect a human or monitoring process to stop it in flight. The control may therefore need to sit earlier in the chain through value limits, beneficiary restrictions, cumulative exposure limits or a requirement for a separate authority decision.

As autonomy grows, humans therefore need to move away from approving every action and towards defining the rules, limits and conditions the system cannot exceed. The aim is not to predict everything the AI might encounter. It is to make sure that uncertainty does not give it unlimited freedom.

3. The Control Illusion

An organisation may have all the expected controls around autonomous AI and still have lost practical control.

It may be able to report that every agent has an identity, authority is documented, least privilege is applied, actions are logged, monitoring is active, human oversight is assigned and shutdown mechanisms have been tested. Everything may appear healthy.

If the system can complete an irreversible action in one second while the control process needs forty seconds to detect, understand and stop it, those controls do not control that action.

The same problem can arise through complexity. A human may have formal approval rights but face more decisions, technical complexity or speed than can realistically be assessed. The problem can also arise across several systems, where a sequence of individually authorised actions combines into an outcome nobody intended.

This is the Control Illusion as the term is used in this paper: the organisation sees the presence of controls and assumes that control follows. It may not.

The useful test is whether a control can actually prevent the unacceptable outcome from occurring. If the organisation can only establish what happened afterwards, it has evidence. It does not have control over that outcome.

The phrase Control Illusion is not claimed here as a new term. It has also been used in recent AI research in a different context to describe failures of instruction hierarchies. The concern here is different: the gap between formal enterprise controls and their practical ability to constrain consequential autonomous action.

4. Control Margin

Control Margin is an attempt to make part of this problem measurable. A control can only affect an outcome while there is still time to affect it.

Control Margin = time available before the outcome becomes unavoidable - total time needed to intervene

The intervention time includes detecting the problem, understanding what is happening, deciding what to do, issuing the intervention and waiting for it to take effect.

Using the payment example, if settlement becomes irreversible after one second but detection takes five seconds, assessment twenty seconds, decision thirty seconds and intervention another four seconds, the control is already fifty-eight seconds too late. The kill switch may work perfectly and still be irrelevant to that transaction.

Control Margin need not always be expressed in seconds. The same idea can be applied to financial exposure, systems changed, records released, agents created or state changes completed before intervention becomes effective. The underlying issue is the same: how far can the system move before the control can still change the result?

Where the margin is too small or already negative, the organisation has three broad options: slow the autonomous system, speed the control process, or move the control earlier by narrowing what the system is allowed to do. The third option becomes increasingly important as autonomy increases.

Control Margin

Does the control process finish before the outcome becomes unavoidable?

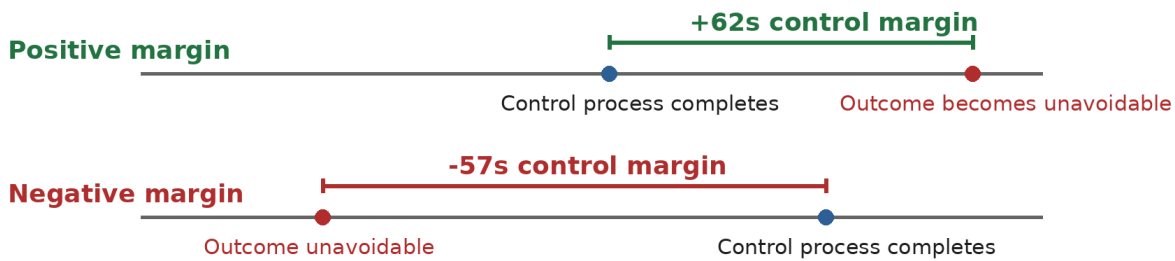


Figure 1. Control Margin: whether intervention can still affect the outcome.

5. IABEI

IABEI stands for Identity, Authority, Boundaries, Evidence and Intervention. None of these control areas is individually new. Their value in IABEI lies in treating them as one connected assurance chain rather than as separate control disciplines.

Identity

Identity is not simply an account name. For consequential action, the organisation needs to establish what acted, on whose behalf and through what chain. A system may contain a human principal, an orchestrating agent, several sub-agents, tools and external services. The chain from the originating principal to the final action needs to remain attributable. “The finance agent did it” is not sufficient assurance.

Authority

An objective is not authority. An agent may be told what outcome to achieve, but that does not give it the right to use every available means of achieving it. An instruction to reduce supplier costs by 10 per cent does not automatically authorise an agent to terminate contracts, create suppliers, move data, change payment terms or grant another agent additional access.

Authority therefore needs four things: source, purpose, scope and duration. Source establishes where the authority came from. Purpose ties it to the objective for which it was granted. Scope defines what the agent may actually do and which resources it may use. Duration establishes when that authority ends. A downstream agent should not acquire more effective authority than the agent or principal that delegated the task unless a new authority decision is made. Authority must also cease when the task is complete, the context changes or the condition that justified it no longer exists. An agent may ask for more authority, but it must not be able to grant that authority to itself.

Boundaries

Permissions describe what an agent may do. Boundaries define what the system must not be allowed to make true.

An agent may be permitted to make payments below £50,000. If it can make one hundred payments of £49,999, the real organisational limit is not £50,000. Likewise, one agent may create an account, another may grant access and a third may add it to a privileged group. Each action may be valid in isolation while the resulting state is not.

The organisation does not need to predict every possible future situation. It does need to define some outcomes that must remain out of reach. These might include total autonomous financial exposure, creating and paying a new supplier in the same autonomous chain, creating and elevating a privileged identity without separate approval, allowing protected data to leave a defined environment or making a production change where rollback has already been lost.

Local validity is necessary. Global admissibility is decisive.

Meta's Muse provides a current example of this kind of separation. Its Sentinel is a separate host-side control that is the sole permission authority for connector actions and network egress. Muse proposes an action; Sentinel decides whether it is allowed, denied or requires user approval. IABEI sits above mechanisms such as Sentinel and asks whether the boundary being enforced is the right one, whether it is tied to the correct authority and whether it remains effective as the wider system changes.

Evidence

Logging is not enough. The evidence needs to allow an independent reviewer to establish what happened, why it was allowed and which authority was used. For consequential action, that means connecting the originating mandate, the identities involved, the authority being exercised, the relevant context, the action taken and the resulting state.

For high-consequence actions, chain-of-custody concepts are useful. The evidence needs reliable provenance and integrity from mandate to outcome. The system being assessed should not be able to erase or rewrite the evidence used to assess it.

Intervention

Intervention is not the same as having a stop button. It means being able to change the outcome while change is still possible. The intervention also has to reach the whole chain that can still produce the consequence. Stopping one agent is not enough if it has already created a sub-agent, queued an instruction, initiated a transaction or triggered another system that will continue independently.

Intervention should therefore be judged against the consequence, not simply against whether the original agent stopped.

6. The links matter

The five IABEI areas only work if they are connected. An identity that cannot be tied to the authority being used is weak. Authority that is not tied to enforced boundaries is weak. Evidence that cannot show which authority produced an action is weak.

Evidence and intervention serve different purposes. Evidence preserves the trusted record needed to reconstruct and challenge what happened. Intervention is driven by current operational signals

such as monitoring, state changes, thresholds, alerts or policy violations. A system can therefore have excellent historical evidence and still detect a developing problem too late, or it can stop a problem successfully while leaving poor evidence afterwards.

This is where IABEI should sit above lower-level controls. Much of the machinery already exists. Zero trust, ACAP, identity platforms, policy engines, provenance systems and runtime controls can all provide parts of the control chain.

IABEI is intended to test the joins between them. The identity presented by the executing agent needs to be tied to the authority being exercised. That authority needs to remain subject to the correct boundary at the point of execution. The evidence needs to preserve the same relationship, and the intervention mechanism needs to be able to act against the same chain.

Lower-level frameworks provide mechanisms. IABEI asks whether the mechanisms form a working control chain.

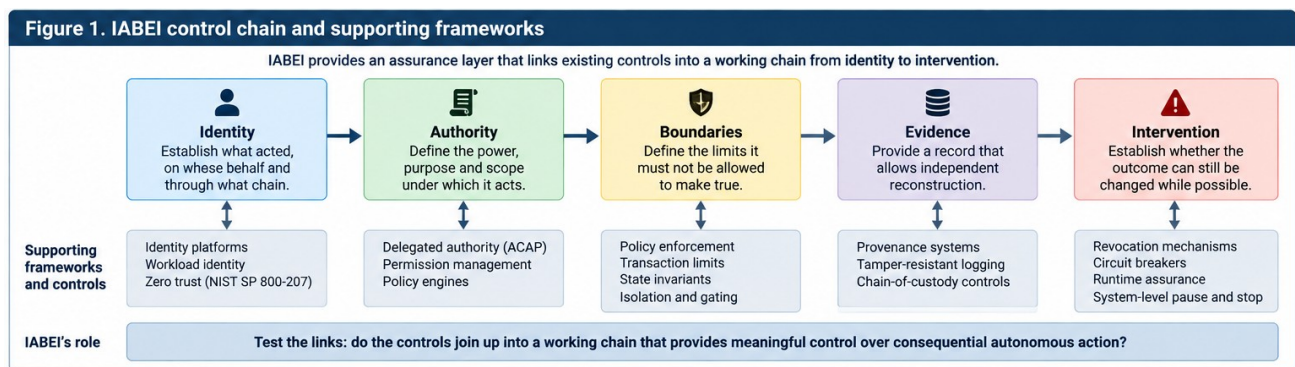


Figure 2. IABEI control chain and examples of supporting frameworks and controls.

7. Removing implicit trust from autonomous action

There is a useful parallel with zero trust. Zero trust removes implicit trust based on network location or ownership and requires access to enterprise resources to be explicitly authenticated and authorised. Autonomous AI creates a similar problem at the action level.

An agent should not be trusted simply because it has already been approved, behaved correctly before, has a valid identity, has a legitimate business objective or is operating inside a trusted environment. Its next consequential action still has to remain inside the authority and limits that apply at that point.

Zero trust removes implicit trust from access. IABEI removes implicit trust from autonomous action.

An agent that was authorised yesterday, or for its previous action, should not automatically inherit trust for the next one. Its instructions may have changed, the data may have changed, the system state may have changed, or the authority under which it was operating may have expired. This does not mean that every action requires the same level of checking. The strength of the control should reflect the potential consequence and how difficult it would be to recover. The starting point remains the same: past approval does not create a standing right to act.

8. Multi-agent systems and global admissibility

Multi-agent systems make the problem harder because every individual agent may be operating correctly while the combined system is not.

One agent may create an account, another may grant access and a third may add accounts to privileged groups. Each agent may have a valid identity, operate within its own authority and pass its local controls. The resulting state can still be an administrator account that nobody intended to create.

The same applies to finance. Ten agents may each be allowed to commit £20,000. If the intended limit on total autonomous exposure is £50,000, checking each transaction independently is insufficient.

The action itself therefore cannot always be the only unit of control. The resulting shared state matters as well. A proposed action needs to be valid in its own right and leave the overall state inside the organisation's limits. That is what this paper calls global admissibility.

Local validity versus global admissibility

Each individual action may be allowed, while the resulting system state is not.

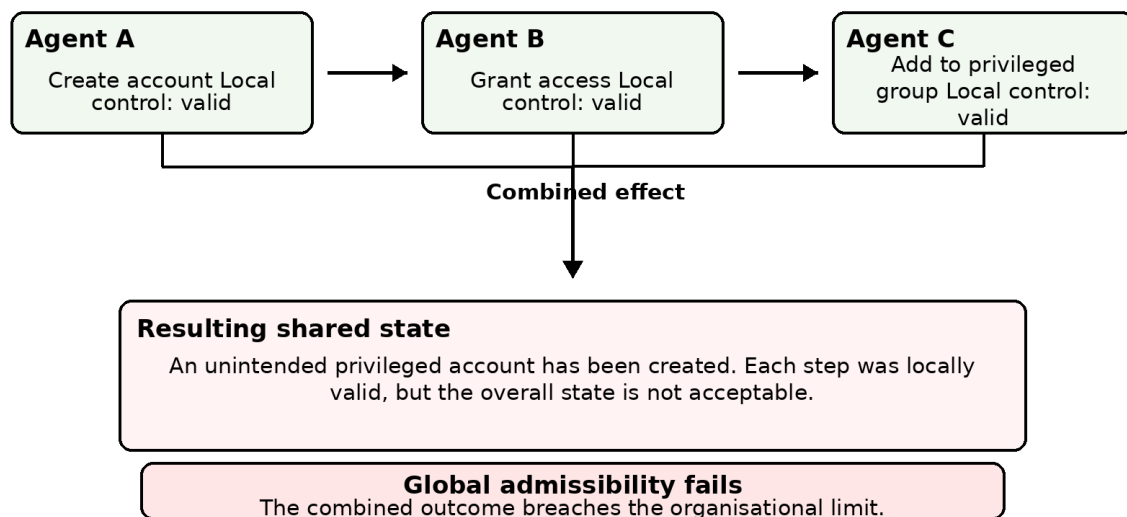


Figure 3. Local validity versus global admissibility in a multi-agent system.

9. Failure independence

More controls do not always mean more control. Suppose one agent decides a payment is valid, a second AI reviews it and a third AI monitors the process. That appears stronger, but it may add little protection if all three use the same underlying model, rely on the same bad data or consume the same compromised context.

The issue is not duplication. It is independence. A control needs enough independence from the system it is controlling to catch the failure that matters. That independence may come from a

different model, an independent data source, a deterministic rule, a separate execution environment or a control the agent cannot alter.

Control redundancy is not control independence.

In some cases the strongest control over an intelligent system may be deliberately unintelligent. A deterministic rule preventing autonomous payments above £100,000 may provide stronger assurance than asking another AI whether a £10 million payment appears reasonable.

10. Human oversight

Human oversight will not scale indefinitely. A human can remain formally responsible while having little practical ability to challenge or stop what the system is doing.

The answer is not to make humans approve everything. It is to move human control to the appropriate level. Humans do not need to anticipate every condition the system might encounter. They do need to decide what the system may do, what it must never do and what should happen when it reaches something outside those limits.

The system can then operate inside those limits without constant human approval. If it reaches the edge, it may stop, request more authority, escalate or hand the decision back. What it should not be able to do is decide that its own limits no longer apply.

The important issue is therefore where meaningful control actually resides. Sometimes that will be with a person. Sometimes it will be in a deterministic technical limit, a policy engine or an independent supervisory system. Eventually it may also involve another AI. The test remains the same: whether the control can still affect the outcome.

11. Future systems

A framework designed only for today's agents will become obsolete quickly.

IABEI has to survive systems that can create new agents, write and deploy software, redesign workflows, build new tools, alter their own structure and create systems humans cannot fully understand. At that point it may no longer be realistic to inspect every internal step.

Some control conditions will need to survive changes to the system itself. The system should not be able to grant itself more authority, remove protected boundaries, rewrite the evidence used to assess it or disable the independent intervention mechanisms that may be needed to stop it.

If an AI designs the operational system, designs the control system, generates the evidence and decides whether its own controls worked, the result may be highly sophisticated while providing little independent assurance.

Future assurance may therefore depend less on humans understanding every internal mechanism and more on demonstrating that certain unacceptable states remain outside the system's reach.

IABEI should define what must remain true rather than prescribe how today's technology should make it true.

Open agents and control across organisational boundaries

Future agent systems are unlikely to remain neatly inside one organisation. An internal agent may call an external agent, which may call another service or agent operated by somebody else. Open interoperability standards such as A2A are explicitly intended to let agents built by different vendors and frameworks collaborate.

Meaningful control does not require an organisation to control every agent in that chain. It does require the organisation to control the authority and state changes it allows those agents to exercise within its own domain. An external agent may operate under another organisation's rules, but when it attempts to move money, alter records, access data or invoke tools inside a different organisation, the receiving organisation's identity, authority and boundary controls still apply.

The harder problem is preserving enough identity, authority and evidence across organisational boundaries to understand the wider chain. That will become increasingly important as open agent protocols and cross-vendor agent ecosystems develop.

12. Testing IABEI

IABEI should not be assessed through a questionnaire alone. The system should have to demonstrate that the controls work under realistic operating conditions.

Identity can be tested by following a task through several agents and tools and establishing whether the full chain remains attributable. Authority can be tested by giving an agent a legitimate objective while withholding one of the permissions it needs and observing whether it stops, requests more authority or attempts to work around the restriction. Boundaries can be tested by allowing a series of individually valid actions that would collectively exceed a global limit. Evidence can be tested by corrupting or removing part of the evidence trail and checking whether the action can still be reconstructed.

Intervention can be tested by measuring how long the full control process takes and comparing that with the time available before the outcome becomes unavoidable. Where real-time intervention is not credible, the assessment should test whether the system has been bounded so that the unacceptable outcome cannot be reached without a separate authority decision.

The result should not simply state that a kill switch exists. It should establish either that intervention worked before the unacceptable outcome became unavoidable or that the system's boundaries prevented that outcome from being reachable in the first place.

13. Stress testing IABEI

IABEI should assume that AI systems will sometimes be wrong, manipulated or hostile. Goal hijacking, inter-agent trust escalation, prompt injection and zero-click chains provide useful stress tests because they attack the difference between what the model believes and what the surrounding control system should allow.

False authority

An external document may tell an agent that it has been granted more authority. The agent may believe it. That should not matter. The real authority must come from a control the content cannot rewrite. The agent cannot be the final judge of its own authority.

Privilege escalation

An agent may legitimately discover that it cannot complete its task with its current access. It can request additional authority. It must not be able to grant that authority to itself or obtain it indirectly through another agent without a new authority decision.

Goal hijacking

A malicious input may change the agent's effective objective while its technical permissions remain unchanged. This is where the purpose element of Authority matters. The authority was granted for a particular purpose; changing the agent's apparent goal does not change that mandate. The agent may still possess the technical permission to act, but the action is no longer authorised if it has moved away from the purpose for which the authority was given.

Zero-click prompt injection

An agent may read a malicious email, webpage, document, tool definition or another agent's output and follow the instructions without any human approving them. IABEI does not need to detect every prompt injection. Its role is to limit what a compromised agent can do.

Once the manipulation has succeeded, the important issue is whether the compromised agent can give itself more authority, cross a protected boundary, alter or erase the evidence, disable intervention or use other agents to extend the damage. If those things remain outside the agent's control, the compromise can be contained even though the model itself was successfully manipulated. The distinction is between preventing the manipulation and containing its consequences.

The framework therefore assumes that the agent can fail. Its purpose is to prevent failure automatically becoming serious consequence.

14. Relationship with existing frameworks

IABEI does not depend on claiming that its individual controls are new. Identity management, zero trust, delegated authority, runtime assurance, provenance, policy enforcement and shutdown mechanisms already have substantial bodies of work behind them.

IABEI should use these mechanisms rather than compete with them. Its proposed role is different: to provide an assurance structure above them and test whether they form an end-to-end chain of meaningful control.

In practice, IABEI could sit across existing agent identity, delegated-authority, policy-enforcement, provenance and runtime-control technologies rather than requiring a separate technical stack.

The mapping itself is not enough. The identity used at execution has to be tied to the authority being exercised. The authority has to be subject to the correct boundary. The evidence has to

preserve that chain. Intervention has to be able to act against the resulting state before the relevant consequence becomes unavoidable.

That linkage is central to IABEI.

15. Model assurance and action assurance

Model assurance and action assurance are different problems. Frontier AI companies are investing heavily in model evaluation, red teaming and forms of embedded assurance. That work matters, but a well-evaluated model can still be placed inside an enterprise agent with too much authority, weak boundaries or an intervention process that is too slow.

A model can therefore behave as designed and still perform an action the organisation should never have allowed. The problem may not be the model. It may be the authority attached to it.

Model assurance is concerned with whether the underlying AI behaves acceptably under defined conditions. Action assurance is concerned with whether a particular exercise of autonomous authority was legitimate and remained under control. IABEI sits mainly in the second category.

16. What IABEI does and does not claim

IABEI does not make autonomous AI safe. It does not solve alignment, eliminate prompt injection, predict every future state or guarantee that humans will always understand what an advanced system is doing. It does not replace the technical controls and frameworks beneath it.

When an organisation gives an AI system the ability to take consequential action, it needs a way to test whether that authority remains under meaningful control. IABEI is intended to provide that structure.

The central problem is the Control Illusion: controls can still exist even when they are no longer capable of preventing the outcome that matters.

The response has three parts. Control Margin asks whether there is still time to change the outcome.

Global admissibility asks what those individually valid actions add up to across agents, systems and time.

IABEI then asks whether the underlying controls are actually connected well enough to work as one chain.

None of those claims requires pretending that the underlying control disciplines are new. The question is whether this combination provides a useful way of determining whether autonomous authority remains genuinely controlled.

Conclusion

AI agents will fail. They will misunderstand instructions, consume bad information, make poor decisions and sometimes be deliberately manipulated. Trying to build a system in which none of those things ever happens is not a realistic control strategy.

The important issue is what follows from that failure.

A system that can expand its own authority, cross hard limits, combine valid actions into an unacceptable result, erase its own evidence or move faster than intervention can still cause serious harm even when the surrounding governance appears strong.

These problems will become more important as autonomous systems move faster, interact with one another and humans move further away from individual actions. That does not mean control has to disappear. It means control has to be designed and tested differently.

Taken together, the five elements should let the organisation establish who acted, under what authority, what remained out of bounds, what evidence was preserved and whether intervention could still change the outcome.

Existing frameworks can provide many of those controls. IABEI tests whether they join up, whether the links between them can be demonstrated and whether the resulting chain still controls what the autonomous system can do.

That is the difference between having controls around autonomous AI and being able to show that those controls still matter.

Selected references

NIST, Zero Trust Architecture (SP 800-207) - <https://csrc.nist.gov/pubs/sp/800/207/final>

World Economic Forum / Capgemini, AI Agents in Action: A Playbook for Trusted Adoption, Authorization and Scaling - <https://www.weforum.org/publications/ai-agents-in-action-a-playbook-for-trusted-adoption-authorization-and-scaling/>

Microsoft Security, Updating the taxonomy of failure modes in agentic AI systems - <https://www.microsoft.com/en-us/security/blog/2026/06/04/updating-taxonomy-failure-modes-agentic-ai-systems-year-red-teaming-taught-us/>

Microsoft Learn, Manage agentic risk - <https://learn.microsoft.com/en-us/security/zero-trust/sfi/manage-agentic-risk>

NASA Technical Reports Server, Runtime Assurance / Simplex related work - <https://ntrs.nasa.gov/citations/20240007986>

Ethics and Information Technology, meaningful human control / autonomous systems literature - <https://link.springer.com/article/10.1007/s11948-025-00554-z>

Meta AI Research, How We Built Safety Into Muse - <https://research.meta.ai/blog/security-and-safety-for-ai-agents-our-approach-with-muse>

Google Developers Blog, Announcing the Agent2Agent Protocol (A2A) - <https://developers.googleblog.com/a2a-a-new-era-of-agent-interoperability/>